System administrator review - server settings

Date: 12 November 2026
Scope: development host 172.16.16.44 (ocrv2), compose environment, Admin > Settings, Admin > System, backups, sessions, mail, VPN, and module controls.
Release: 2.7.0.

Verdict

The operational baseline is sound: single-worker backend, non-root container, socket proxy, Valkey, Postgres tuning, health checks, and a signed supply-chain lock. The remaining work is configuration discipline, not missing features.

Findings and recommendations

Critical (complete before production)

1. Rotate every secret that still has a default. Confirm JWT_SECRET, WG_ENCRYPTION_KEY, REPORT_SIGNING_KEY, PEER_MANAGER_API_KEY, and POSTGRES_PASSWORD are unique per host and stored only in .env (mode 600). WG_ENCRYPTION_KEY must be a Fernet key; keep WG_ENCRYPTION_KEY_PREVIOUS only during a rotation and remove it after the re-encryption pass.
2. Require MFA for admin and instructor accounts. The setting exists; turn it on for the production host and keep recovery codes offline.
3. Keep API docs disabled. ENABLE_API_DOCS must be unset/false and the admin setting enable_api_docs must be false. Verify /docs, /redoc, and /openapi.json return 404.
4. Run a real restore drill. A backup that has never been restored is a hope. Restore the newest snapshot into a scratch database, verify row counts and login, then record the time and result.

High

5. Verify Peer Manager exposure. Bind must be the Docker bridge gateway or loopback, never 0.0.0.0; the API key must be present or the service must refuse to start. Confirm port 5000 is closed at the host firewall.
6. Set REPORT_SIGNING_KEY explicitly. Falling back to JWT_SECRET works, but separate keys limit blast radius and make rotation independent.
7. Review CORS and public host. CORS_ORIGINS must list only the real origin; SERVER_PUBLIC_HOST must match the certificate and the links in mail and certificates.
8. Turn on log rotation for lab containers. json-file with max-size=10m and max-file=3 prevents a long-running range from filling the disk.
9. Add retention jobs. Prune data_integrity_ledger, activity_events, and flag_attempts on a schedule; keep the audit window the policy requires.

Medium

10. Keep the pool at 10+10 for the single-worker shape. If you scale workers, raise max_connections or lower the pool so (pool + overflow) x workers stays below the server limit.

11. Keep the slow-query log on. log_min_duration_statement=200 and a monthly review is the cheapest performance tool available.
12. Pin base images by digest. --check-pins is informational today; make it blocking when the supply-chain lock is next regenerated.
13. Confirm mail TLS and sender policy. Use ssl.create_default_context, a dedicated sender, and SPF/DKIM/DMARC for the domain.
14. Keep the software-integrity check visible. Admin > System > Software should be run after every deploy; a mismatch means the mounted labs are not the reviewed release.

Low

15. Archive the stale duplicate repositories on the build workstation; keep one source of truth.
16. Record the host's Docker, Postgres, and OS versions in versions.yaml after each upgrade.
17. Review the module toggles quarterly; disabled modules still ship code and should be intentional.

Quick wins (under one hour)

Action | Why
Rotate default secrets and store .env at mode 600 | Removes the most common compromise path
Enable admin MFA | Blocks credential replay
Confirm /docs returns 404 | Reduces API surface
Set Docker log rotation | Prevents disk-full lab spawn failures
Run Admin > System > Software | Proves the deployed labs match the release

Sign-off

Reviewed by: System Administrator review (OpenCyberRange upgrade gate)
Date: 2026-11-12
Status: conditional - critical items 1-4 must be completed on the production host before the release gate can pass.